

AI Prompt Injection Checklist

Direct and indirect injection — the six surfaces, controls, and tests

Prompt injection is the top LLM risk: untrusted text reaches the model and is interpreted as instructions. It comes in two forms. **Direct** — a user types the malicious instruction. **Indirect** — the instruction is hidden in content the agent reads (a document, a web page, a tool response), so the agent is attacked without the user doing anything. Indirect is the dangerous one, and the one most reviews miss.

The six injection surfaces

An agent can be injected through any channel that carries text into the model. Enumerate all six for every agent — a defense on the input box does nothing for a poisoned PDF.

Surface	Where the instruction hides	Direct / Indirect
Input	The user's own prompt / chat message	Direct
Memory	Prior turns or stored context poisoned earlier	Indirect
Resource / file	Uploaded or retrieved documents (RAG)	Indirect
Tool	Data returned by a tool or API call	Indirect
Website	Pages the agent browses or fetches	Indirect
Multimodal	Instructions inside an image, PDF, or audio	Indirect

Controls to verify

Injection cannot be fully “prompt-engineered” away — treat the model as persuadable and put deterministic controls around it.

Control	What good looks like
Privilege separation	The model cannot invoke high-impact actions directly; a deterministic layer gates them. Instructions from data are never trusted like instructions from the user.
Input / content isolation	Retrieved and tool content is clearly delimited and treated as data, not commands. Untrusted HTML/markdown is sanitized.
Output constraints	Responses are schema-validated; the agent cannot emit arbitrary tool calls from free text.
Human-in-the-loop	Consequential actions require explicit approval regardless of what the prompt says.
Logging & detection	Prompts, retrieved content, and tool calls are logged so injection attempts are visible to the SOC.

How to test (authorized lab only)

Probe each surface with benign, well-known patterns and record whether the agent obeys the injected instruction or holds its guardrails. Test **multiturn** (build the attack over several messages) and **indirect** (plant the instruction in a document or page the agent reads) — single-shot tests miss the realistic attacks.

Probe type	What you are checking
Instruction override	Does the agent abandon its system prompt when told to ignore prior instructions?
Indirect payload	Plant an instruction in a test document / page — does the agent execute it?
System-prompt leak	Can the agent be coaxed into revealing its system prompt or hidden config?
Multimodal payload	Does text embedded in a test image or PDF get followed?

Framework mapping

A confirmed injection weakness maps at once to: **OWASP LLM01 (Prompt Injection)**, and where it drives an action, **OWASP LLM06 (Excessive Agency)** and **OWASP Agentic ASI02 (Tool Misuse)**; **MITRE ATLAS — LLM Prompt Injection / Jailbreak**; **NIST AI RMF (Measure, Manage)**; **ISO/IEC 42001**; and **EU AI Act Art.14 (human oversight)** where a consequential action is reachable. One finding, mapped to every obligation.

Reviewer's quick checklist

- All six injection surfaces enumerated for this agent (not just the input box).
- Indirect surfaces (files, tools, websites, multimodal) explicitly tested.
- High-impact actions gated by a deterministic layer, not model judgment.
- Retrieved / tool content isolated and treated as data, not instructions.
- System prompt not leakable; output schema-validated.
- Multiturn and indirect probes run in an authorized lab; results logged.
- Findings mapped through the crosswalk with an "assessed as of" date.

Safety. Use safe sample data only. Never use real credentials, tokens, or customer data, and never test production systems. Any dynamic probing runs only against an explicitly authorized lab or staging environment, and all results are labeled as authorized testing.